

Vulnerability Risk Assessment Workshop

scan_results.json

Vul

[HIGH] core-banking-app - Microsoft SQL Server Remote Code Execution via Malformed Query (CVE-2019-1068)

[HIGH] online-banking-web - nginx Range Filter Integer Overflow (CVE-2022-41741)

[MEDIUM] legacy-reporting-svc - OpenSSH Pre-Authentication User Enumeration (CVE-2018-15473)

[MEDIUM] hr-payroll-db - PostgreSQL Privilege Escalation via ALTER ... DEPENDS ON EXTENSION (CVE-2020-14349)

Risk register for track_b_northbridge_financial (without intel update):

[14.00] core-banking-app Microsoft SQL Server Remote Code Execution via Malformed Query (CVE-2019-1068)

[12.00] online-banking-web nginx Range Filter Integer Overflow (CVE-2022-41741)

[5.94] hr-payroll-db PostgreSQL Privilege Escalation via ALTER ... DEPENDS ON EXTENSION (CVE-2020-14349)

[5.80] legacy-reporting-svc OpenSSH Pre-Authentication User Enumeration (CVE-2018-15473)

Phase 4 — Threat Modeling Workshop

Finding (host/CVE)	STRIDE category	Threat description	Existing or missing control	Framework mapping
Core-banking app (CVE-2019-1068 – 14.00	Elevation of privilege	Microsoft SQL Server Remote code execution via malformed query	Least privilege, patch management, and use OWASP recommended allow -list validation	TTP (attacker could attempt to execute commands on the server to gain access, or steal data)
Online-banking-web (CVE-2022-4174 1) – 12.00 CRITICAL	Tampering	Nginx Range Filter Integer Overflow	Patch management (regularly), along with regular vulnerability scanning	TTP (an attacker could corrupt data, and interfere with work causing DoS)
HR-payroll-db (CVE-2020-1434 9) – 5.94	Elevation of privilege	PostgreSQL privilege escalation via alter	ABAC (or some kind of least privilege) - MFA	TTP (someone could authenticate to this system, and execute SQL commands with privileges of replicated user to gain PII)
Legacy-reporting-SVC (CVE-2018-1547 3)	Information disclosure	Open SSH pre-authentication user enumeration	Restrict exposure of SSH (port 22), with firewall rules, use trusted networks (VPNs), vulnerability scanning	TTP (an attacker can determine whether a particular username exists on an SSH server by sending crafted authentication requests and observing differences in the server's response) recon

Phase 5 — Executive Communication Deliverable

Executive summary

-A recent scan of Northbridge Financial systems has shown us some vulnerabilities, 3 of which require immediate attention. The core banking app, the online banking web, and the HR-payroll database. The core banking app is at risk of having its server accessed by an attacker, and potentially exposing PII of customers, and financial data. The online banking web is in danger of being shut down as a service by an attacker, which could cause financial loss, and reputational damage. The HR payroll database is at risk of being hacked, and exposing sensitive data (PII) of our employees. We recommend the following controls to address these vulnerabilities: patch core-banking app, and implement least privilege, with allow-list validation within the week. Patch the online banking web, and implement active monitoring for vulnerabilities, also within the week. Also, implement MFA, and ABAC controls for the HR database, as well as the other two within the month. If these issues are not addressed this institution risks exposing customer and employee PII, and other sensitive financial data. This could cause us to become non-compliant with PCI-DSS and SOX, not to mention any reputational damage, or loss of trust from customers, and public at large.